Governance Gap Analysis Template										
RAI Principle	***Policy Section***	***RAI Control ID***	***RAI Control Description***	***Current State***	***Gap Description***	***Severity Rating***	***Owner***	***Target Date***	***Priority***	***Status***
Accountability	***Policy 8.2***	RAI-3.1	***Organizations must develop and document an AI incident response plan to address harm caused by unintended AI system behaviors, such as the generation of biased, unsafe, or factually incorrect outputs.***	***Covers only traditional security incidents, as the unauthorized access, disclosure, or loss of sensitive company or customer data.***	***Complete absence of protocols or procedures for addressing unintended AI system behaviors and clinical harms.***	***critical***	***Executive Management***	***30 days from approval***	***1***	***open***

Transparency	*Complete Absence*	*RAI-* 2.4	*provide documentation describing the AI system's purpose, capabilities, limitations, and training data characteristics for internal stakeholders*	*No current policy requires the documentation or disclosure of AI model capabilities, limitations, or training data features*	*Internal stakeholders lack documentation on AI purpose, limitations, and training data.*	*Significant*	*Head of AI Governance / Legal Counsel*	*90 days from approval*	*3*	*open*
Fairness										
Reliability & Safety	*Policy 9.1: System Change Control*	*RAI-* 4.2	*Provide a mechanism for appropriate human review, intervention, safe interruption, or override*	*Requires formal change requests, descriptions, rollback plans,*	*Lacks specific operational mechanisms for human-in-the-loop review, real-time intervention,*	*Critical*	*Head of Clinical Operations*	*50 days from approval*	*2*	*open*

			before high-stakes decisions take effect	***and director-level approval for IT production changes.***	***and emergency overrides for high-stakes AI diagnostic tools.***					

Note: Microsoft does not publicly publish a rigid control ID catalog like ISO or NIST. What I created here is a practitioner-grade control mapping derived from:

**** Microsoft Responsible AI principles***

**** Their internal standard structure (governance, validation, documentation, oversight)***

That's actually how most enterprises operationalize it.

2. Prioritized Backlog Entries (Azure DevOps Ready)

Backlog Item 1: Develop AI Incident Response Plan & Procedures

- **Severity:** Critical
- **Assigned Policy Owner:** Chief Data Officer / Head of InfoSec
- **Recommended Sequence:** 1

- **Governance Rationale:** This item is prioritized first because failing to address unintended AI behaviors such as biased or unsafe clinical outputs creates an immediate patient safety hazard and severe regulatory compliance risk.

Backlog Item 2: Implement Human-in-the-Loop Review and Override Mechanisms

- **Severity:** Critical
- **Assigned Policy Owner:** Head of Clinical Operations
- **Recommended Sequence:** 2
- **Governance Rationale:** This item is ranked second because deploying high-stakes AI diagnostic tools without mandatory human oversight and safe override controls poses unacceptable risks to patient health outcomes.

Backlog Item 3: Establish AI System Documentation and Transparency Standards

- **Severity:** Significant
- **Assigned Policy Owner:** Head of AI Governance / Legal Counsel
- **Recommended Sequence:** 3
- **Governance Rationale:** This item is placed third as it addresses regulatory alignment and internal audit readiness regarding system capabilities and training data limitations, which are essential for long-term governance